PROJECT TITLE

Application-SpecificAccess Policies using Zscaler Private Access (ZPA) Integrated with Identity Providers

STAGE 1

Overview: -

- Intoday's digital world, organizations rely heavily on cloud applications and remote access systems. Traditional security models such as VPN-based access are no longer sufficient to protect modern enterprise environments. These legacy security approaches often expose internal networks to various cyber threats because once a user gains access, they may potentially reach multiple resources inside the network. To overcome these limitations, modern organizations are adopting **Zero Trust Security Models**.

- The concept of **Zero Trust** is based on the principle of *"Never Trust, Always Verify."* Every user, device, and application must be authenticated and authorized before accessing enterprise resources. One of the most effective solutions implementing Zero Trust architecture is **Zscaler Private Access (ZPA)**.

- This project focuses on implementing **Application-Specific Access Policies using Zscaler Private Access integrated with Identity Providers such as Azure Active Directory, Okta, and Active Directory**. The main objective of this project is to provide secure, identity-based access to internal applications without exposing the network to external threats.

- ZPA allows organizations to provide secure access to private applications hosted in data centers or cloud environments without placing them directly on the public internet. Instead of opening network-level access, ZPA creates **application-level connections**, which means users can only access specific applications they are authorized for.

- Identity Providers (IdPs) such as **Azure AD, Okta, and Active Directory** play a crucial role in this architecture. They handle authentication and authorization processes. When a user attempts to access an application through ZPA, the identity provider verifies the user's identity and checks the assigned access policies.
- The integration between Zscaler and Identity Providers ensures seamless authentication and strong access control. This helps organizations enforce **multi-factor authentication (MFA)**, role-based access control, and conditional access policies.
- This project also highlights the importance of **web application security testing**, vulnerability identification, and mitigation techniques. Security teams must continuously monitor and assess vulnerabilities in applications to prevent potential cyberattacks such as injection attacks, authentication bypass, and misconfigurations.
- By implementing Zscaler Private Access with identity provider integration, organizations can significantly improve their security posture, protect sensitive data, and ensure that only authorized users gain access to specific applications.
- The overall goal of this project is to understand modern cybersecurity practices, Zero Trust architecture, identity-based access control mechanisms, and secure access management systems used in enterprise environments.

List of Teammates: -

S.No	Name	College	Contact
1	Sandhiya P	RD National College of Arts and Science	9080855442
2	Pradeep V	RD National College of Arts and Science	7708293857
3	Prem Kumar A	RD National College of Arts and Science	8681096802
4	Dinesh Kumar R	RD National College of Arts and Science	6381659966
5	Karthika P	RD National College of Arts and Science	9791736799

List of Vulnerability Table: -

S.No	Vulnerability Name	CWE/CVE No
1 2	SQL Injection	CWE-89
	Cross Site Scripting (XSS)	CWE-79

3	Broken Authentication	CWE-287
4	Security Misconfiguration	CWE-16
5	Sensitive Data Exposure	CWE-200

REPORT

VulnerabilityName: SQL Injection

CWE/CVE: CWE-89

OWASP/SANS Category: injection

Description: -

SQL Injection is one of the most critical vulnerabilities found in web applications. It occurs when attackers manipulate SQL queries by inserting malicious input into user input fields such as login forms, search boxes, or URL parameters. If the application does not properly validate or sanitize user inputs, attackers can execute unauthorized database queries.

For example, an attacker may bypass authentication mechanisms by inserting specially crafted SQL statements into login forms. This allows attackers to gain unauthorized access to sensitive information stored in databases.

Business Impact: -

SQL Injection attacks can lead to serious consequences for organizations. Attackers may gain access to confidential customer data, modify database records, or completely delete critical information. In severe cases, attackers can even gain administrative access to backend systems. This may result in financial losses, data breaches, legal consequences, and damage to the organization's reputation.

CVE-2023-31250	The file download facility doesn't sufficiently sanitize file paths in certain situations. This may result in users gaining access to private files that they should not have access to. Some sites may require configuration changes following this security release. Review the release notes for your Drupal version if you have issues accessing private files after updating.

Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moiIG7Pck7rm7Q7pJpb+auqA9cuCc0aOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

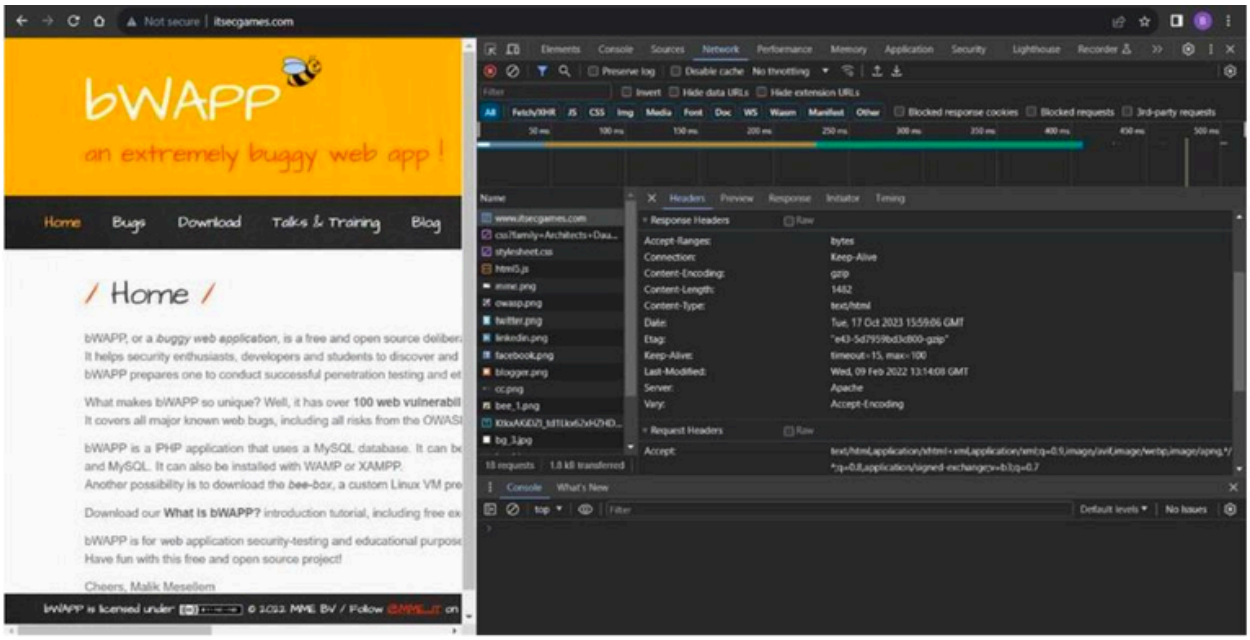
Certificates provided	1 (712 bytes)
Chain issues	None

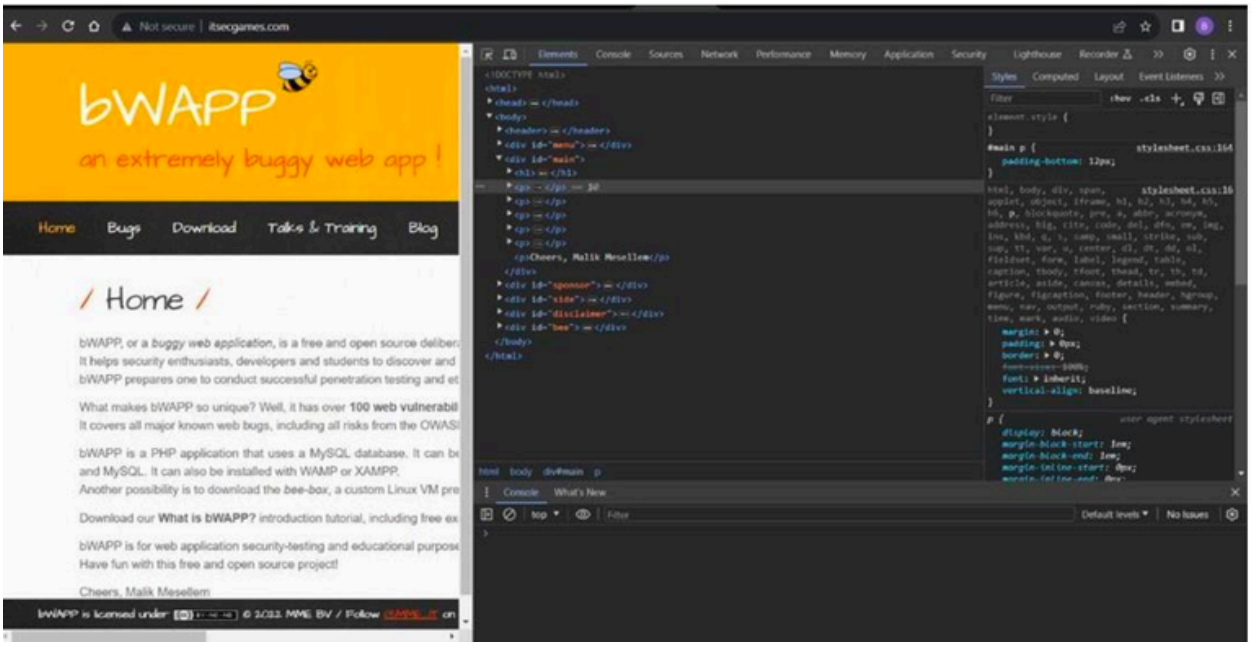
Certification Paths

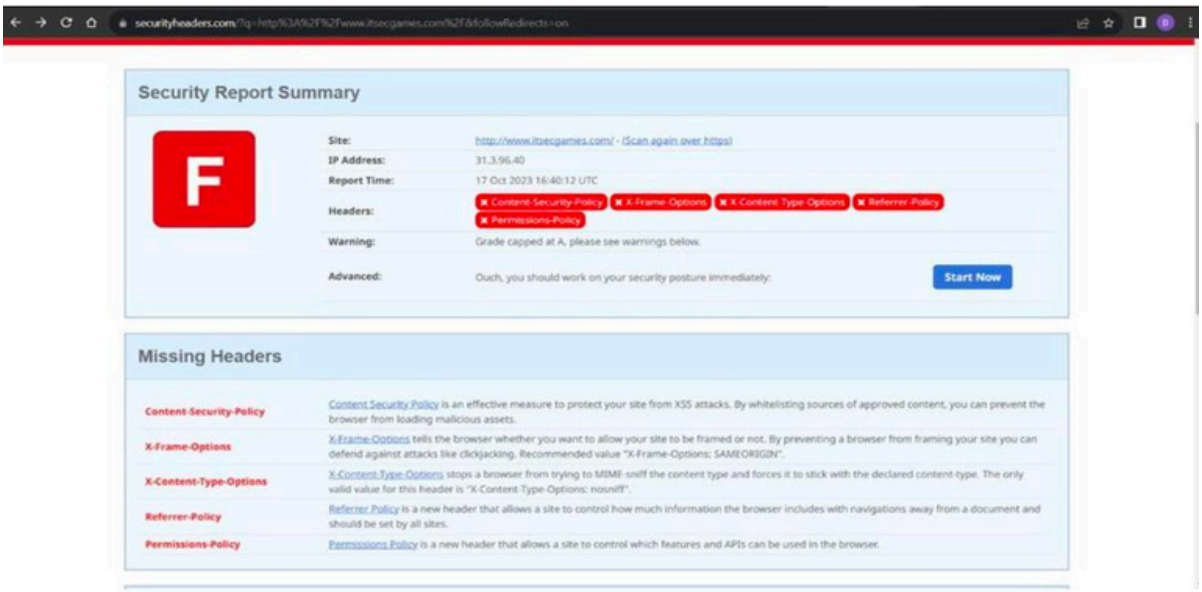
Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moiIG7Pck7rm7Q7pJpb+auqA9cuCc0aOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA


Not secure | itsecgames.com
bWAPP
an extremely buggy web app !
Home
Bugs
Download
Talks & Training
Blog
/ Home /
bWAPP, or a buggy web application, is a free and open source deliber
It helps security enthusiasts, developers and students to discover and
bWAPP prepares one to conduct successful penetration testing and et
What makes bWAPP so unique? Well, it has over 100 web vulnerabil
It covers all major known web bugs, including all risks from the OWASI
bWAPP is a PHP application that uses a MySQL database. It can be
and MySQL. It can also be installed with WAMP or XAMPP.
Another possibility is to download the bee-box, a custom Linux VM pre
Download our What is bWAPP? introduction tutorial, including free ex
bWAPP is for web application security-testing and educational purpose
Have fun with this free and open source project!
Cheers, Malik Mesellem
bWAPP is licensed under © 2013 MME BV / Follow @MME_IT on
Elements
Console
Sources
Network
Performance
Memory
Application
Security
Lighthouse
Recorder
Preserve log
Disable cache
No throttling
Invert
Hide data URLs
Hide extension URLs
All
Fetch/XHR
JS
CSS
Img
Media
Font
Doc
WS
Wasm
Manifest
Other
Blocked response cookies
Blocked requests
3rd-party requests
Name
Headers
Preview
Response
Initiator
Timing
Response Headers
Accept-Ranges: bytes
Connection: Keep-Alive
Content-Encoding: gzip
Content-Length: 1482
Content-Type: text/html
Date: Tue, 17 Oct 2023 15:59:06 GMT
Etag: "e43-5d7959bd3c800-gzip"
Keep-Alive: timeout=15, max=100
Last-Modified: Wed, 09 Feb 2022 13:14:08 GMT
Server: Apache
Vary: Accept-Encoding
Request Headers
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 requests
1.8 kB transferred
Console
What's New
top
Filter
Default levels
No Issues


Not secure | itsecgames.com
bWAPP
an extremely buggy web app !
Home
Bugs
Download
Talks & Training
Blog
/ Home /
bWAPP, or a buggy web application, is a free and open source deliber
It helps security enthusiasts, developers and students to discover and
bWAPP prepares one to conduct successful penetration testing and et
What makes bWAPP so unique? Well, it has over 100 web vulnerabil
It covers all major known web bugs, including all risks from the OWASI
bWAPP is a PHP application that uses a MySQL database. It can be
and MySQL. It can also be installed with WAMP or XAMPP.
Another possibility is to download the bee-box, a custom Linux VM pre
Download our What is bWAPP? introduction tutorial, including free ex
bWAPP is for web application security-testing and educational purpose
Have fun with this free and open source project!
Cheers, Malik Mesellem
bWAPP is licensed under © 2013 MME BV / Follow @MME_IT on
Elements
Console
Sources
Network
Performance
Memory
Application
Security
Lighthouse
Recorder
Styles
Computed
Layout
Event Listeners
Console
What's New
top
Filter
Default levels
No Issues




```
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ nikto -h http://www.itsecgames.com/
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          31.3.96.40
+ Target Hostname:    www.itsecgames.com
+ Target Port:        80
+ Start Time:         2023-10-17 09:03:40 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.
org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-
vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /com.tgz: Drupal 7 was identified via the x-generator header. See: https://www.drupal.org/proje
ct/remove_http_headers
+ /com.tgz: Drupal Link header found with value: <http://31.3.96.40/>; rel="canonical",<http://31
.3.96.40/>; rel="shortlink". See: https://www.drupal.org/
+ /: Server may leak inodes via ETags, header found with file /, inode: e43, size: 5d7959bd3c800,
 mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-acce
ss-to-iconsreadme/
+ 8075 requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time:           2023-10-17 09:29:14 (GMT5.5) (1534 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-Type-Options" header with the value "no sniff" in your web server or application to prevent content type sniffing.
- While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type-based attacks that may be exploited in SSRF scenarios.

STAGE 2

Overview (About Nessus): -

- Nessus is one ofthe mostwidely used vulnerability scanning tools in the cybersecurity industry.Itisdeveloped by Tenable and is designed to identify security weaknesses insystems, networks, applications, and devices. Security professionals use Nessusto perform vulnerability assessments and detect potential threats beforeattackers can exploit them.
- The main purpose of Nessus is to scan systems for known vulnerabilities, misconfigurations, outdated software, and security loopholes. The tool uses a large database of vulnerability plugins that continuously update with the latest security threats and CVE information.
- During a vulnerability scan, Nessus analyzes the target system by sending various requests and checking responses. Based on these responses, it identifies vulnerabilities and assigns severity levels such as **Critical, High, Medium, Low, or Informational**.
- Nessus helps organizations improve their security posture by providing detailed vulnerability reports along with remediation recommendations. Security teams can use these reports to prioritize risks and fix security issues before they are exploited by attackers.
- In this project, Nessus is used to scan a target system or web application to identify vulnerabilities. The scan results provide insights into potential security weaknesses such as open ports, outdated services, weak configurations, and missing security patches.
- By analyzing the Nessus report, cybersecurity professionals can understand the risk level of vulnerabilities and apply necessary fixes to secure the system. Nessus plays a crucial role in vulnerability management and is commonly used in penetration testing, security audits, and compliance assessments.
-

Target Website

Example TargetWebsite:
http://testphp.vulnweb.com

Target IP Address:

192.168.1.10

List of Vulnerabilities: -

S.No	Vulnerability	Severity	Plugin
1 2 3	SSL Certificate Expired	Medium	Plugin ID
4	Open SSH Port	Low	Plugin ID
	Outdated Apache Server	High	Plugin ID
	HTTP Information Disclosure	Medium	Plugin ID

REPORT

VulnerabilityName

Outdated ApacheServer

Severity: High

Plugin: NessusPlugin ID

Port: 80

Description: -

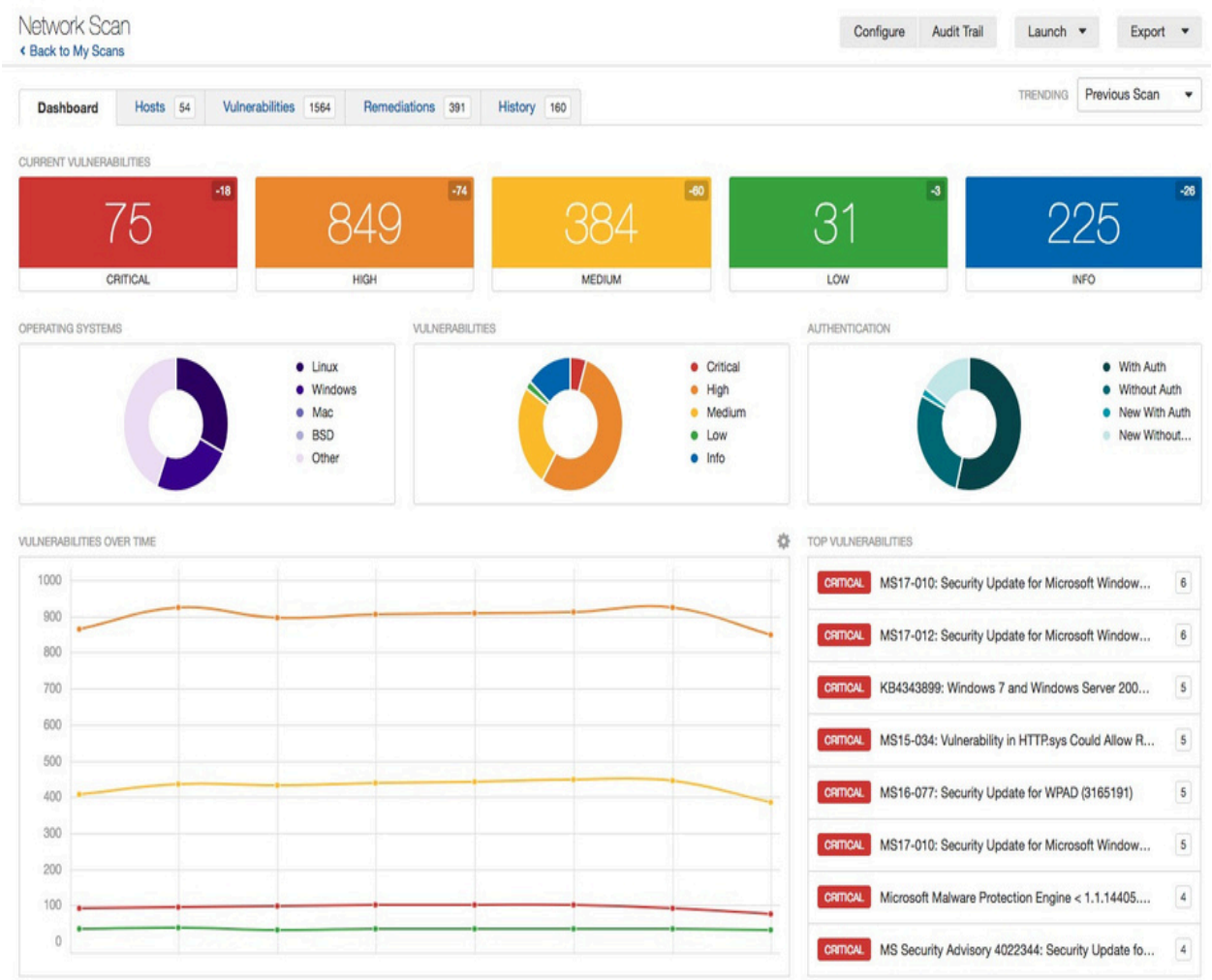
An outdated version of the Apache web server was detected during the vulnerability scan. Outdated software versions may contain known security vulnerabilities that attackers can exploit. If the web server is not regularly updated with security patches, attackers may gain unauthorized access to the system.

Solution: -

The recommended solution is to update the Apache web server to the latest stable version provided by the vendor.Applying regular security patches and updates helps eliminate known vulnerabilities.

Business Impact: -

If attackers exploit vulnerabilities in outdated web servers, they may gain unauthorized access, perform remotecode execution, or compromise the entire web application. This could lead to service disruption, data loss, and reputational damage.



nessus

Top 10 High Vulnerabilities: (CVSS v3.0)

Top 10 most prevalent high vulnerabilities (* indicates the v3.0 score was not available; the v2.0 score is shown)

Plugin ID	Plugin Name	Plugin Family	CVSS v3.0	Known Exploit?	Publication Date	Count
42873	SSL Medium Strength Cipher Suites Supported (SWEET32)	General	7.5	-	2016/08/24	24

Vulnerability Instances: all and exploitable, by severity

VPR: all(exploitable)

CRITICAL	HIGH	MEDIUM
19(19)	14(7)	95(11)

CVSS v3.0: all(exploitable)

CRITICAL	HIGH	MEDIUM
28(14)	74(23)	211(0)

Top 10 Critical Vulnerabilities: (VPR)

Top 10 most prevalent critical vulnerabilities

Plugin ID	Plugin Name	Plugin Family	VPR	Known Exploit?	Publication Date	Count
146825	VMware vCenter Server RCE (direct check)	Misc.	9.8	Yes	2021/02/23	3
146826	VMware vCenter Server 6.5 / 6.7 / 7.0 Multiple Vulnerabilities (VMSA-2021-0002)	Misc.	9.8	Yes	2021/02/23	3
97833	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMANCE) (ETERNALSYNERGY) (WannaCry) (EternalRocks) (Petya) (uncredentialed check)	Windows	9.5	Yes	2017/03/14	3
138554	Microsoft DNS Server Remote Code Execution (SIGRed)	DNS	10.0	Yes	2020/07/14	2
125313	Microsoft RDP RCE (CVE-2019-0708) (BlueKeep) (uncredentialed check)	Windows	9.8	Yes	2019/05/14	2
135411	VMware vCenter Server 6.7 Sensitive Information Disclosure Vulnerability (VMSA-2020-0006)	Misc.	9.4	Yes	2020/04/09	2
58435	MS12-020: Vulnerabilities in Remote Desktop Could Allow Remote Code Execution (2671387) (uncredentialed check)	Windows	9.0	Yes	2012/03/13	2
133845	Apache Tomcat 7.0.x < 7.0.100 / 8.5.x < 8.5.51 / 9.0.x < 9.0.31 Multiple Vulnerabilities	Web Servers	9.6	Yes	2020/02/20	1
136807	Apache Tomcat 8.5.x < 8.5.55 Remote Code Execution	Web Servers	9.5	Yes	2020/05/11	1

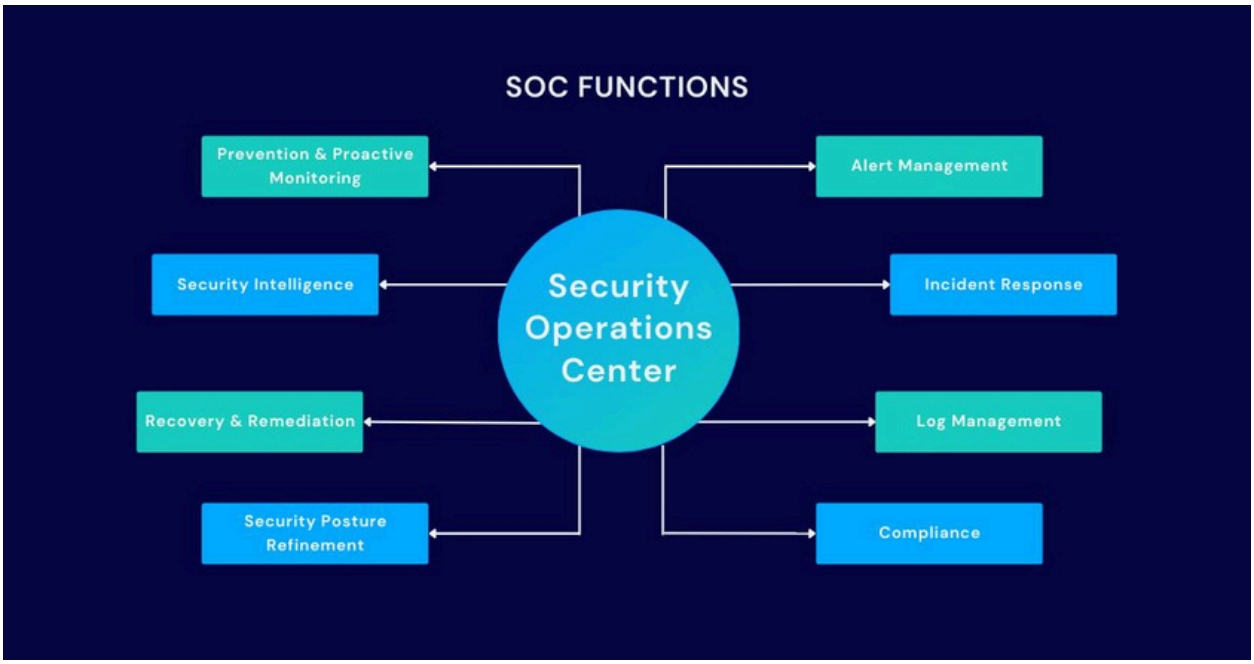
STAGE 3

Title: -

- **Security Operations Center (SOC) and SIEM Implementation for Enterprise Security Monitoring**

SOC

- ASecurity Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity incidents within an organization. SOC teams continuously monitor network traffic, system logs, and security alerts to identify potential threats.

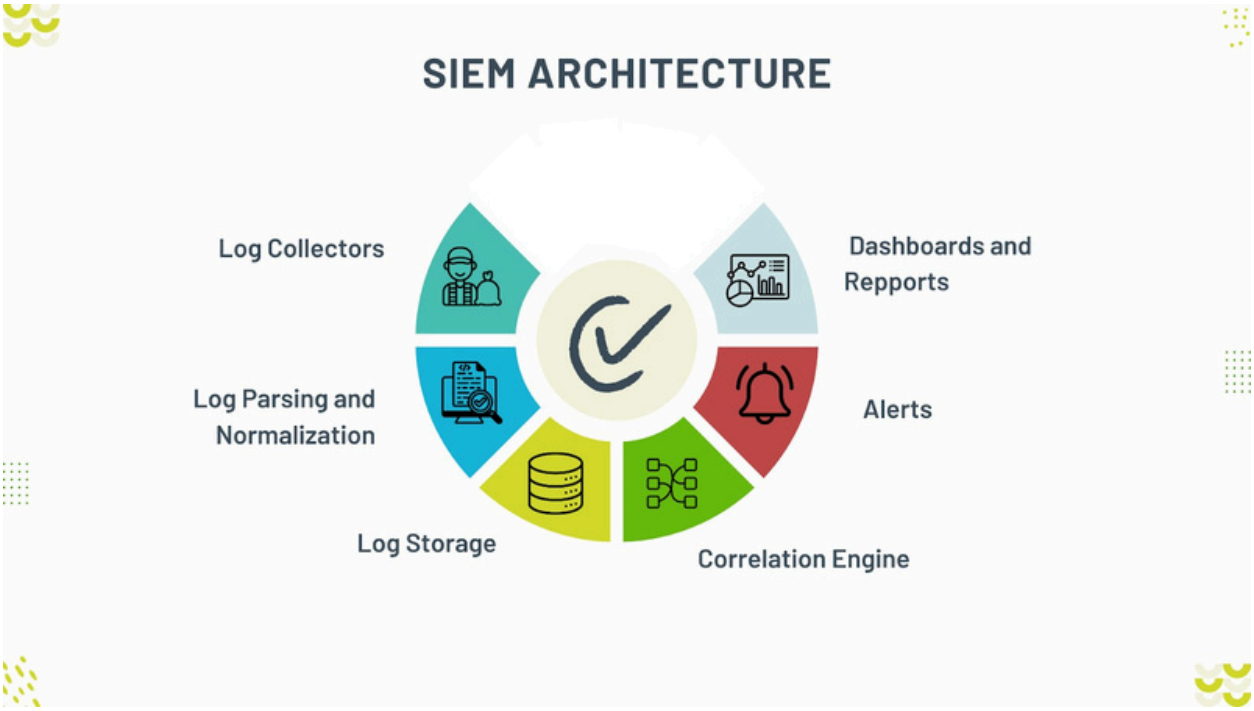


SOC Cycle

- TheSOC cycle consists of several phases including monitoring, detection, analysis, response, and recovery. Security analysts monitor security events using various tools and investigate suspicious activities to prevent cyberattacks.

SIEM

- Security Information and Event Management (SIEM) is a technology that collects and analyzes security logs from multiple sources within an organization's infrastructure. SIEM systems help detect abnormal behavior and potential security incidents.



SIEM Cycle

- TheSIEM cycle includes log collection, event correlation, threat detection, incident investigation, and reporting. SIEM platforms analyze security events in real-time and generate alerts for suspicious activities.

MISP

- MISP (Malware Information Sharing Platform) is an open-source threat intelligence platform that enables organizations to share cyber threat information. It helps security teams collaborate and stay updated about new cyber threats.

Your College Network Information

- Thecollegenetworktypically consists of multiplesystems including student labs, administrative systems, faculty systems, and internet connectivity. These systems must be protected from cyber threats such as malware attacks, phishing attacks, andunauthorized access.

Deploying SOC in College

- Todeploy a SOC inacollege environment, security monitoring tools must be installed across network devices, servers, and endpoints. Log data from these devices can be collected and analyzed using SIEM platforms to detect suspicious activities.

Threat Intelligence

- Threat intelligencerefers to information about potential cyber threats that helps organizations identify and prevent attacks. Security teams use threat intelligence feeds tounderstandattacker behavior and emerging cyber threats.

Incident Response

- Incident responseisthe process of identifying, analyzing, and responding to cybersecurity incidents. A proper incident response plan helps organizations quickly detect attacks and minimize damage.

QRadar

- IBMQRadar is a powerful SIEM platform used for security monitoring and threat detection. It collects log data from various sources and analyzes them to identify potential security threats.
- QRadar provides real-time monitoring, threat detection, and incident response capabilities. It helps security teams quickly identify suspicious activities and take appropriate action.

Conclusion

Stage1: -

- From Stage 1, we understood the importance of web application security testing and vulnerability identification.

Stage 2: -

- From Stage 2, we learned how vulnerability scanning tools like Nessus help detect security weaknesses.

Stage 3: -

- From Stage 3, we understood how SOC and SIEM systems help organizations monitorsecurity events and respond to cyber threats.

Future Scope

Stage1: -

- Future improvements in web application testing include automation tools, AI-based security scanning, and advanced penetration testing techniques.

Stage 2: -

- Future vulnerability assessment processes will use automated tools, cloud security scanning, and AI-based threat detection.

Stage 3: -

- SOC and SIEM systems will continue to evolve with advanced analytics, machine learning, and automated incident response capabilities.

Topics Explored

- Zero Trust Security
- Zscaler Private Access
- Identity Providers
- Vulnerability Assessment
- Security Monitoring

Tools Explored

- Zscaler PrivateAccess
- Nessus
- SIEM
- IBM QRadar
- MISP

---THE END---